

XA-Guard

面向政企智能体的身份约束、六关防护与可验证撤销

项目编号：XA-202620

D1 技术方案报告

工程冻结版 · 仓库安全封面

XA-Guard Project · 2026-07

摘要

大模型智能体把自然语言决策连接到检索、文件、脚本、浏览器和业务接口，安全边界因而从“生成内容是否合规”扩展到“谁委托了哪个 Agent、它是否有权执行、真实副作用能否恢复、全过程是否可验证”。XA-Guard 提供一个位于智能体与工具之间的安全代理：以 OIDC 双主体身份和动态 assignment 约束委托关系，以 Gate1-6 控制输入、审批、策略、污点、沙箱与审计，以 intent-first Effect 记录真实副作用，并通过独立审批与 Worker 补偿完成可验证 Undo。

项目覆盖赛题四个方向：复杂输入链路攻击识别、工具调用与任务执行安全、插件/Skill/脚本供应链安全、政企场景评测与审计溯源。主评测采用独立的 Open Agent Range 企业靶场：Null 与 XA-Guard live A/B 各重复 3 次，Null 3/3 发生泄漏，XA-Guard 3/3 阻断，infra error 为 0，protection_delta 为 1.0；full-day 场景产生 41 次工具尝试、43 条 ledger 记录和 0 个 ledger violation，7/7 attempt replay 通过哈希、ledger 与原始 XA-Guard 审计对齐。

最终工程候选在 Reference Compose 中通过全故障 11/11，在本地三节点 kind profile 中通过安装、升级、迁移重跑、API Pod 删除、Worker lease 接管、NetworkPolicy 正负探针和 Helm 回滚。正式 10 并发三轮 500 paired writes 的增量 p95 为 45.109/42.141/43.934ms，单侧 95% bootstrap upper 为 46.984/43.120/45.528ms，均不超过 50ms；10 次 Undo 均在 0.45-0.94s 内完成。

关键词：智能体安全；MCP；OIDC；提示注入；工具治理；AIBOM；审计溯源；补偿事务

1. 问题、目标与评价口径

1.1 政企智能体的风险变化

传统问答系统的主要输出是文本，而智能体会把不可信输入转化为高权限动作。风险可沿五个层面传播：

- 用户输入、网页、附件、知识库和历史记忆携带直接或间接提示注入。
- 模型生成的工具参数越过人员、Agent、数据域或预算边界。
- 插件、Skill、脚本和依赖包引入恶意逻辑、隐蔽外联或能力声明漂移。
- 高风险写操作产生真实副作用，单纯“记录日志”无法恢复业务。
- 身份、决策、审批、执行和恢复证据分散，难以回答责任归属与复现问题。

安全目标因此不是单点分类器，而是贯穿“评测—防护—审计—恢复”的闭环。

1.2 设计目标

目标	可验证定义
身份可信	人员通过 OIDC 登录；Agent token 含 human sub、agent act.sub/azp 和 tenant
授权实时	每次调用读取 PostgreSQL assignment，并与静态 YAML ceiling 求交
执行受控	Gate1-6 对输入、审批、策略、污点、沙箱和审计形成固定顺序
副作用可恢复	写操作先登记 Effect intent；可逆合同经独立审批后执行补偿
证据可验证	Gate6 与 Effect 双链、原/补偿 trace、业务引用可交叉验证
原型可复现	Compose、Helm/kind、测试脚本、签名 evidence 和 release manifest 可独立运行

1.3 明确边界

XA-Guard 是竞赛原型和工程验证，不宣称生产多地域 HA、绝对 exactly-once、通用数据库回滚、第三方 TSA/HSM 或组织级外部 IdP 已落地。不可逆动作进入 manual_required；可逆动作采用至少一次调度与下游幂等。历史研究矩阵、Trae native elicitation、gVisor 全验收和第三方 notarization 不作为本次比赛硬门槛。

2. 威胁模型

2.1 受保护资产

- 政企业务数据、知识库、文件和接口凭据。
- 人员身份、Agent 身份、租户边界和动态授权关系。
- 工具调用参数、审批决定、恢复合同和业务前后状态。
- Gate6 审计链、Effect 事件链、签名 evidence 和发布 provenance。

2.2 对手能力

对手可以构造恶意提示和间接指令、污染工具输出、伪造普通 HTTP header、诱导越权工具调用、提交恶意插件包、篡改未保护的日志或利用服务中断制造半完成状态。对手不能伪造 IdP 私钥、读取 gitignored 的运行密钥或突破宿主与容器本身的基础安全边界。

2.3 关键安全不变量

- 无有效双主体身份或 assignment 时，业务写入数和 Effect 增量均为零。
- prepared Effect 成功持久化之前不得调用下游。
- Undo 申请人与审批人不得为同一 subject。
- 补偿必须重新经过 Governance 与 Gate1-6。
- 同租户 Effect/Gate6 链尾按固定顺序加锁并以 CAS 推进。
- 证据中不保存 token、密码、私钥、DSN、恢复材料或内部审批凭据。



3. 总体架构

XA-Guard 的主形态是 MCP/HTTP 安全代理。上游可以是 IDE、办公 Agent 或 Open Agent Range；下游是搜索、文件、脚本或真实业务 API。控制面由身份、assignment、策略、审批和审计构成；数据面按固定六关处理每次调用；恢复面围绕 Effect 与 Worker 运转。



核心数据流：

```
human sub → Agent act.sub/azp → tenant
→ dynamic assignment ∩ YAML ceiling
→ Governance → Gate1-6
→ prepared Effect → business side effect → available
→ independent approval → signed compensation
→ Governance → Gate1-6 → compensated → evidence
```

3.1 六关职责

关卡	核心职责	失败行为
Gate1	输入攻击识别、规则/模型融合、Spotlighting	拒绝或降级
Gate2	风险分级、审批与 pending	高风险无批准不执行
Gate3	工具、参数、域和 overlay policy	默认拒绝越界
Gate4	污点标签与外发控制	敏感流向阻断
Gate5	沙箱路由、资源和网络约束	不满足 profile 不执行
Gate6	决策、身份、证据与哈希链	审计持久化失败则写路径失败关闭

3.2 部署形态

Reference Compose 提供 PostgreSQL、Keycloak、business-api、xa-guard、Worker 与 Console/BFF。Helm chart 提供 API/Worker 多副本、migration Job、PDB、NetworkPolicy、Secret 引用和回滚路径。开发默认绑定 localhost；远程环境必须配置 TLS、组织 IdP、托管数据库、KMS/HSM、备份和监控。

4. 核心创新一：human→Agent 双主体身份

传统共享 API key 只能说明“某客户端调用过”，无法证明“哪个人委托了哪个 Agent”。XA-Guard 使用 Authorization Code + PKCE 完成人员登录，由 confidential BFF 执行 RFC 8693 token exchange；Agent token 在浏览器持久存储中不可见。

交换后的声明同时携带人员 sub、Agent act.sub/azp、tenant、audience 和有效期。服务端忽略客户端自报的 x-agent-id、x-tenant-id 等普通 header，授权只依赖签名 token 和持久化 assignment。

动态 assignment 描述 human/group 可以委托哪些 Agent，以及 Agent 可使用的工具与数据域。每次请求都在 PostgreSQL 中实时匹配，并与静态 YAML ceiling 求交；撤销无需等待 token 过期即可生效。Reference fault suite 验证了未认证、错误签名、错误 audience、伪造 azp/sub/tenant、assignment 立即撤销和跨租户隔离。



5. 核心创新二：intent-first Effect 与可验证 Undo

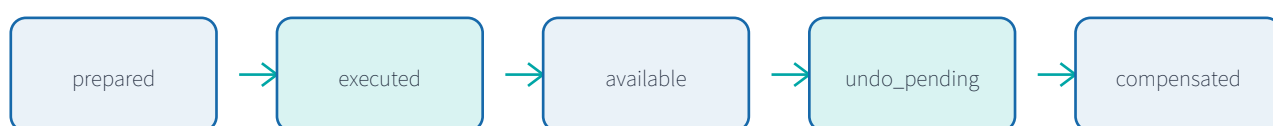
5.1 为什么日志不足

审计日志能回答“发生过什么”，不能把一张错误工单恢复为 cancelled。XA-Guard 把副作用建模为 Effect：它包含工具、数据域、人员、Agent、原 trace、幂等键、恢复合同摘要、Undo 窗口和状态机。

5.2 intent-first 写入顺序

写操作先在 PostgreSQL 原子写入 prepared Effect 与 pre-approval Gate6，再调用下游。下游以 effect_id 作为幂等键。响应前，系统写入 completed/available Effect 与 final Gate6。若数据库不可用，调用在下游之前失败；若 API 在业务成功后崩溃，reconciler 根据持久化 intent 与下游幂等状态恢复为 available。

5.3 Undo 状态机



申请人提交理由后形成 pending Undo。审批端验证同租户、角色、窗口与职责分离；批准只调度任务，不在请求线程直接执行补偿。Worker 通过 lease/heartbeat 取得任务，解密 v2 恢复合同，生成内部签名授权，再次执行 Governance 与六关。失败按 5/30/120 秒持久化计划重试；不可逆动作转 manual_required。

5.4 一致性与并发

Effect 与 Gate6 使用同租户统一调度和微批。prepared/final 各自保持原子 CTE、固定双链锁顺序和链尾 CAS；同一调度周期的 final 与 prepared 可复用连接和事务，仍保持 final→prepared 顺序。同一 Undo 并发双审批只生成一个逻辑任务，响应为一个 200 和一个 409。

6. 方向一：复杂输入链路攻击识别

Gate1 对用户输入、工具描述、网页/文档内容和检索片段做统一规范化。规则层覆盖常见注入、越狱、数据外发和指令覆盖信号；Spotlighting 对不可信内容做结构隔离；模型后端可按配置接入并与规则分数融合。检测结果进入 Gate6，后续审批和策略可以使用同一风险标签。

CSAB-Gov-mini 提供 290 条 PoC seed，用于回归而非宣称满足 GB/T 45654 完整题库规模。独立 holdout/formal dual-500 已退役为比赛硬指标；报告不把训练内 seed 的表现包装成独立泛化结论。

OAR 从企业场景层面补足单句分类的不足：攻击通过网页、附件、工具输出或供应链 finding 进入任务链，最终以真实 SUT 的阻断、业务后果和审计对齐判断效果。

7. 方向二：工具调用与任务执行安全

Gate2-5 把“模型想调用工具”转化为有边界的执行决策：

- Gate2 根据工具能力、数据域、参数和风险分级选择 allow、deny 或 pending。
- Gate3 使用静态策略与 overlay predicate 做工具、域和参数约束；策略缺失时失败关闭。
- Gate4 传播敏感标签并限制外部地址、日志和响应中的数据流。
- Gate5 将高风险命令路由到只读根、非 root、资源限制和网络受控的容器 profile。

Reference Console 展示真实 Alice/Dora 双人闭环。Alice 只看到 assignment 授权的 general-office-agent；创建工单后可申请 Undo，但无审批角色。Dora 独立登录后批准，Worker 再次过六关执行 business_cancel_ticket。前端不提供角色切换，因此不会把 UI 伪装当成身份隔离。

8. 方向三：插件、Skill 与脚本供应链

XA-Guard AIBOM gateway 将组件准入放在安装/执行之前。输入可以是内部清单或由 OWASP cdxgen 生成的 CycloneDX 1.6 BOM；系统执行 schema/结构检查、组件与依赖提取、MCP/AI 能力标记、策略评分、签名或 HMAC 验证，并给出 admit/deny 结果。

离线 install_plugin 只在 AIBOM 准入后复制允许的工件，拒绝路径穿越、隐藏危险文件和不匹配的能力声明。R8 外部生成器验收保留 cdxgen 版本、命令、BOM、XA-Guard 结果和 artifact hash。第三方 marketplace/IDE native hook 不作为已完成承诺。

依赖引用来自 Apache-2.0、MIT、BSD、Python-2.0、ISC、MPL-2.0 等允许使用的开源许可证；HA 工具的 kind、Kubernetes、Helm 和 Calico 来源及许可证记录在 THIRD_PARTY_NOTICES。

9. 方向四：评测、审计与持续优化

9.1 Open Agent Range

OAR 是独立企业红队靶场，而不是官方 benchmark 的替代品。它包含人员、Agent、工具面、数据域和业务后果，支持 finding、full-day、Null/XA-Guard A/B、attempt ledger、replay 和 promote。



live A/B 的每次 attempt 都启动真实 xa_guard.server MCP session，保留 sut-session、调用投影与 raw audit 对齐信息。保护效果使用 protection_delta、violations、external sends 和 replay 结果表达，不误写成 AgentDojo ASR。

9.2 Gate6 与证据封存

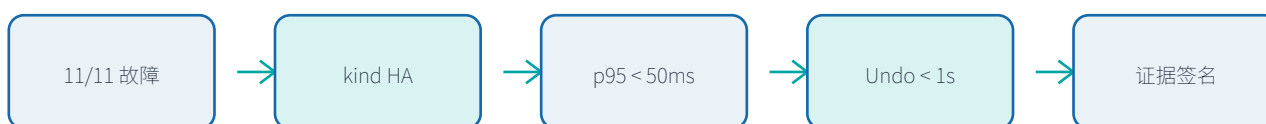
Gate6 记录输入/输出摘要、身份、Agent、工具、数据域、策略、审批、风险、faithfulness evidence 和哈希前驱。Effect 事件链记录 prepared、available、undo_requested、approved、compensation_started、compensated 等状态。两条链使用 trace、effect_id 与业务引用交叉关联。

Identity + Undo evidence collector 从 PostgreSQL 读取链前缀与业务状态，执行 secret scan、链重算、cross-link 检查和 acceptance assertion，再以 SM2-with-SM3 签名 artifact manifest。独立 verifier 固定 signer key id，任何内容、顺序、签名或引用篡改都会失败。

10. 实验设计与结果

10.1 主结果

实验	方法	结果
OAR live A/B	Null/XA-Guard, 各 N=3, 真实 MCP SUT	Null 3/3 泄漏; XA-Guard 3/3 拦截; delta 1.0
OAR full-day	六域正常日与业务链	41 attempts; 43 ledger; 0 violation
OAR replay	hash + ledger + SUT audit	7/7 PASS
Reference all-fault	core/long/keys 共 11 场景	11/11 PASS
kind HA	三节点、N-1→N、故障与回滚	7 个 required phase 全 PASS
正式并发性能	10 并发、3×500 paired writes	p95 与 bootstrap upper 均 ≤50ms
Undo 时延	独立审批与真实业务取消	10/10, 0.45–0.94s



10.2 all-fault 覆盖

core 覆盖身份拒绝、伪造 header、assignment 撤销、跨租户、PostgreSQL 中断、prepared-effect 恢复和并发双审批; long 覆盖 60 秒 lease holder 被杀后的接管与 5/30/120 秒重试; keys 覆盖错误 KEK 失败关闭、admin retry、KEK 轮换、在线 DEK rewrap 和旧记录恢复。

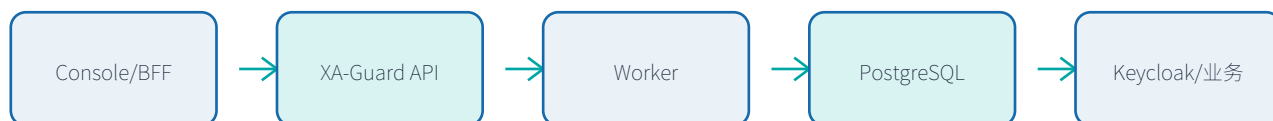
10.3 性能方法

每个 pair 包含一次受保护写和一次直接业务写，AB/BA 顺序确定性平衡并打乱。指标是 protected_ms - direct_business_baseline_ms 的增量 p95，并通过 5000 次非参数 bootstrap 计算单侧 95% upper。完整重建镜像三轮为：

seed	incremental p95	bootstrap upper	判定
20260741	45.109ms	46.984ms	PASS
20365470	42.141ms	43.120ms	PASS
20470199	43.934ms	45.528ms	PASS

该优化未关闭 fsync、synchronous_commit 或 full_page_writes，也未删除 faithfulness evidence 或放宽响应前审计持久化。

11. 工程复现、运维与安全



11.1 最小复现

```
python -m pip install -r requires.txt
python -m pytest -q -p no:cacheprovider
python scripts\reference_stack.py up
python scripts\verify_reference_e2e.py
python scripts\verify_reference_faults.py --suite all
```

统一发布验证还包含 pip check、产品 Ruff、L3 static、Compose config、Console test/build 和签名 evidence verifier。release manifest 仅允许在干净 worktree 上生成，并绑定 commit、branch、tracked file size 与 SHA-256。

11.2 密钥与隐私

Reference 密码、client secret、KEK、内部签名 key、KMS token 和 DSN 位于 gitignored .runtime。Evidence collector 不输出 bearer token、恢复材料或内部审批凭据。最终报告、视频和仓库安全版不写学校或个人信息。

11.3 生产化清单

生产部署仍需组织 IdP 生命周期、TLS/mTLS、托管 PostgreSQL 备份与 PITR、正式 KMS/HSM、容量与 SLO、日志保留和访问审计、灾备演练、漏洞与依赖治理、跨地域一致性验证。

12. 应用价值、限制与结论

XA-Guard 适用于政务办公助手、知识检索、业务流程、运维协同和其他具备工具调用能力的智能体。它以代理方式接入，不要求业务团队改写模型；动态 assignment 和 YAML ceiling 适合组织授权；Effect/Undo 把“发现错误”扩展为“在合同边界内恢复错误”；OAR 和签名 evidence 使评审、审计和持续改进共享同一组可复核事实。

限制包括：Gate1 seed 是 PoC 缩减集；OAR ReactiveSeat 是确定性状态机，不代表完整 7×24 沙盘；kind 只证明本机三节点 profile；可验证 Undo 只覆盖声明了 v2 恢复合同的动作；外部生产设施尚需落地。

本项目的核心贡献不是再增加一个孤立分类器，而是把身份、授权、六关、真实副作用、独立审批、补偿和证据连接为一条可执行链。最终候选已经满足比赛原型可复现、关键流程可演示、主要结果可量化和声明边界可审计的要求。

参考资料

- 中国雄安集团数字城市科技有限公司：《面向政企场景的大模型智能体安全关键技术研究比赛方案》，题号 XA-202620。
- Model Context Protocol Specification，稳定协议与工具调用模型。
- IETF RFC 7636：Proof Key for Code Exchange。
- IETF RFC 8693：OAuth 2.0 Token Exchange。
- OWASP CycloneDX 1.6 Specification。
- AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents, NeurIPS 2024。
- InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated LLM Agents, ACL 2024。
- CaMeL: Defeating Prompt Injections by Design, 2025。
- IsolateGPT: An Execution Isolation Architecture for LLM-Based Agentic Systems, NDSS 2025。
- 仓库内 DELIVERY-v2、EVIDENCE-CONSOLIDATION、Identity + Undo 架构与最终签名 evidence。